DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

CARRERA: INGENIERÍA DE SOFTWARE

NRC: 36893

ASIGNATURA: ING. SEGURIDAD DEL SOFTWARE

TEMA: Simulación de phishing, monitoreo y reducción de riesgo

Nombre:

- Marcelo Acuña
- Abner David Arboleda Roman
- Andrés Isaias Cedeño Cuenca
- Zaith Alejandro Manangón Vinueza

DOCENTE: Ing. Milton Arguello

FECHA: 22 de octubre del 2026

Informe técnico — Simulación de phishing, monitoreo y reducción de riesgo

1. Objetivo

El proyecto mide cuánto reduce el riesgo un bloqueo temporal de cuenta con registro de auditoría, frente a un portal sin controles, dentro de un laboratorio aislado.

Objetivo general. Simular un ataque de phishing con enlace y código QR contra una aplicación de prueba, observar sus efectos en el tráfico y los registros, aplicar controles y comparar el riesgo antes y después en dos servidores web (Apache y NGINX).

Objetivos específicos.

1. Montar un laboratorio aislado con dos usuarios, un servidor Apache, un servidor NGINX y una máquina de monitoreo con OWASP ZAP.
2. Publicar la misma aplicación con formulario de acceso y una cuenta ficticia en ambos servidores.
3. Capturar el tráfico HTTP con ZAP y registrar los eventos de autenticación sin guardar contraseñas ni tokens.
4. Implementar un bloqueo temporal tras 3 intentos fallidos consecutivos, que rechace también la contraseña correcta mientras dura.
5. Construir las matrices de riesgo inicial y residual con la misma escala y relacionarlas con NIST CSF 2.0 e ISO/IEC 27005.
6. Comparar el estado antes y después, y el comportamiento de Apache frente a NGINX.

2. Antecedentes

Este proyecto se apoya en dos normas de gestión (ISO/IEC 27001 y 27005), en el marco NIST CSF 2.0, en una herramienta de monitoreo (ZAP) y en dos casos reales de phishing con QR o enlace corto.

2.1 ISO/IEC 27001 e ISO/IEC 27005

ISO/IEC 27001:2022 (edición 3, 25 de octubre de 2022) especifica los requisitos para establecer, implementar, mantener y mejorar un sistema de gestión de seguridad de la información, e incluye requisitos para evaluar y tratar los riesgos (IEC Webstore, 2022a). Una organización que declara conformidad no puede excluir ninguna de sus cláusulas 4 a 10.

ISO/IEC 27005:2022 (edición 4, 25 de octubre de 2022) es la guía para gestionar los riesgos de seguridad de la información. Ayuda a cumplir los requisitos de 27001 sobre las acciones para abordar riesgos, con énfasis en la evaluación y el tratamiento (IEC Webstore, 2022b).

El proyecto sigue el proceso general de gestión de riesgos que la norma describe: establecer el contexto, identificar, analizar y evaluar los riesgos, tratarlos, aceptar el riesgo residual, y comunicar y monitorear. (La lista de etapas es el esquema general de la norma y no se pudo contrastar con su texto completo, que es de pago; verifíquela con la copia de la universidad antes de entregar.)

Etapa del proceso	Dónde aparece en el proyecto
Contexto	Laboratorio aislado, cuenta ficticia, alcance del ejercicio
Identificación	Activos, amenazas y vulnerabilidades de la matriz inicial
Análisis y evaluación	Probabilidad × impacto en escala 1–5
Tratamiento	Bloqueo temporal, registro de auditoría, endurecimiento de encabezados
Riesgo residual	Matriz residual con la misma escala
Monitoreo	Registro de auditoría, registros de acceso y captura con ZAP

2.2 NIST CSF 2.0

El NIST Cybersecurity Framework 2.0 (NIST, 2024) organiza la ciberseguridad en seis funciones. Las definiciones siguientes son las del propio documento.

Función	Definición del CSF 2.0	Uso en el proyecto
Gobernar (GV)	"The organization's cybersecurity risk management strategy, expectations, and policy are established"	Reglas del laboratorio y alcance (limitado)
Identificar (ID)	"The organization's current cybersecurity risks are understood"	Matriz de riesgo inicial
Proteger (PR)	"Safeguards to manage the organization's cybersecurity risks are used"	Bloqueo temporal, encabezados, cuenta ficticia
Detectar (DE)	"Possible cybersecurity attacks and compromises are found and analyzed"	Registro de auditoría, ZAP, análisis de logs
Responder (RS)	"Actions regarding a detected cybersecurity incident are taken"	Solo recomendado, no implementado
Recuperar (RC)	"Assets and operations affected by a cybersecurity incident are restored"	Solo recomendado, no implementado

Las categorías que usa la matriz son PR.AA (Identity Management, Authentication, and Access Control), PR.AT (Awareness and Training), PR.DS (Data Security), PR.PS (Platform Security) y DE.CM (Continuous Monitoring), con DE.AE (Adverse Event Analysis) para el análisis de eventos.

2.3 ZAP (Zed Attack Proxy)

ZAP es un proxy intermediario: se sitúa entre el navegador y la aplicación y permite ver "all of the requests you make to a web app and all of the responses you receive from it", y modificarlas al vuelo con puntos de interrupción (ZAP, s. f.). En el laboratorio se usa solo para observar: el usuario 1 navega a

través de ZAP y el usuario 2 va directo, para comparar lo que ve cada punto de captura. No se utilizó su escaneo activo.

2.4 Casos reales de phishing con QR o enlace corto

Caso	Qué pasó	Vector	Lección
Ecuador. Alerta por estafa a través de WhatsApp y códigos QR (La Prensa, 22 de noviembre de 2024)	El 21 de noviembre de 2024 usuarios de varias provincias reportaron notificaciones falsas de infracciones de tránsito que circulaban por WhatsApp e imitaban comunicaciones oficiales. Incluían un código QR que supuestamente daba información sobre una multa. Alertaron la Empresa de Movilidad de Cuenca y el Consejo de Seguridad Ciudadana. El objetivo era robar datos personales o bancarios (Peñafiel Robalino, 2024).	**Código QR** en un mensaje de WhatsApp con colores y formato oficial	No escanear QR que lleguen por medios no oficiales y conocer los canales oficiales para notificaciones de tránsito
Ecuador. Aviso de seguridad EC-2022-41, campaña de phishing contra Banco Pichincha (EcuCERT, 25 de febrero de 2022)	Correos con enlaces que imitaban la web del banco para captar credenciales de la banca electrónica. El aviso la clasifica como fraude de riesgo alto y publica un dominio ajeno al banco como indicador de compromiso (EcuCERT, 2022).	**Enlace engañoso** en un correo; el aviso no menciona acortadores ni QR	Verificar que el dominio corresponda a la empresa y que el sitio use HTTPS; bloquear los indicadores de compromiso
Internacional, enlace corto. Phishing a clientes de Banco Bradesco con enlaces bit.ly (30 de marzo de 2011)	Correos con enlaces acortados a sitios falsos. Se registraron 1.735 clics y cerca de 5,24 % lo reportaron; el enlace fue desactivado tras más de una hora (Segu-Info, 2011).	**Enlace acortado** que oculta el dominio real	El acortador impide ver el destino; el tiempo de reacción del proveedor importa

El caso del QR en WhatsApp es el más cercano al laboratorio: un mensaje que aparenta ser oficial y un QR cuyo destino no se ve antes de abrirlo. En las fuentes ecuatorianas revisadas no se encontró un caso que documente un enlace acortado; por eso se añade el caso de Bradesco para ese vector. Los datos se tomaron de las fuentes enlazadas y deben contrastarse si el docente pide fuentes primarias.

2.5 Apache frente a NGINX

La tabla separa lo que dice la documentación oficial de lo que se observó en este laboratorio.

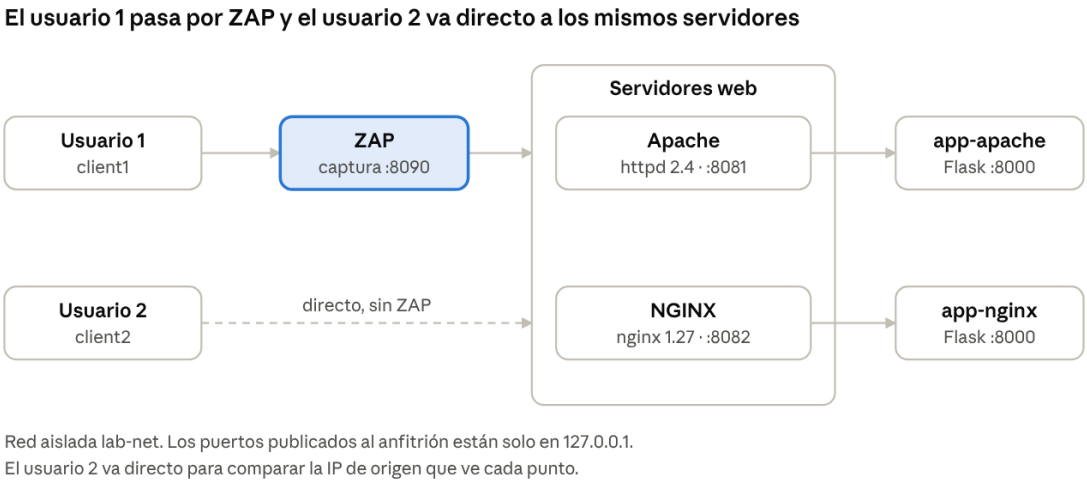
Aspecto	Apache HTTP Server 2.4	NGINX	Tipo de dato
Modelo de concurrencia	MPM `event`: procesos con hilos; un hilo listener gestiona los sockets en keep-alive y los hilos worker solo atienden peticiones activas (Apache Software Foundation, s. f.)	Un proceso maestro y procesos worker de un solo hilo, orientados a eventos y no bloqueantes (Garrett, 2015)	Documentación
Conexiones ociosas	El listener las espera sin ocupar un hilo worker	Cada conexión añade un descriptor y poca memoria al worker	Documentación
Estilo de configuración	Directivas en `httpd.conf`; los módulos de proxy se cargan con `LoadModule`	Bloques `http`/`server`/`location` en `nginx.conf`; `proxy_pass` ya viene integrado	Observado (archivos del repositorio)
Resolución del servidor de aplicación	Resolvió `app-apache` sin ajustes	Con un nombre de host fijo falló al arrancar ("host not found in upstream"); se resolvió con `resolver` y una variable	Observado
Encabezado `Server`	Se reemplazó con `Header always set Server "Apache"`	Se ocultó el del backend con `proxy_hide_header Server`	Observado (curl -I)
Resultado del escenario de bloqueo	3 fallos → 401; 4.º intento → 429; clave correcta durante el bloqueo → 429; después → 302	Idéntico	Observado
Rendimiento y escalabilidad	No se midió	No se midió	No evaluado

La igualdad de resultados en el bloqueo es esperable: la lógica está en la aplicación y ambos servidores solo reenvían la petición. Las diferencias de rendimiento que describe la documentación no se probaron aquí y no deben presentarse como resultados del proyecto.

3. Diseño

El diseño tiene dos vistas: la red del laboratorio, que muestra quién habla con quién, y la secuencia de una petición de acceso, que muestra qué se registra y qué responde la aplicación.

3.1 Diagrama de red



red del laboratorio · 2 usuarios, ZAP, 2 servidores, 2 aplicaciones

El usuario 1 envía su tráfico a través de ZAP, que lo reenvía a Apache o a NGINX; el usuario 2 va directo. Cada servidor reenvía a su propia copia de la aplicación.

3.2 Diagrama de secuencia (UML)

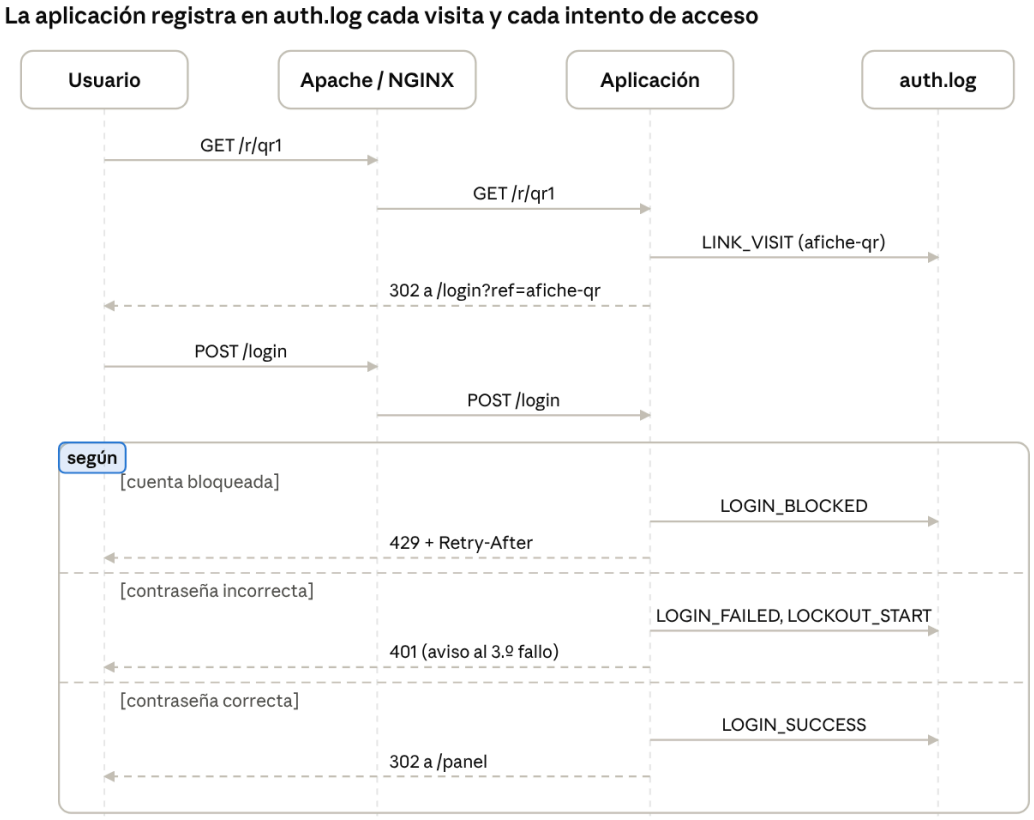


diagrama de secuencia UML · enlace corto y acceso al login

El servidor reenvía la petición con el encabezado `X-Forwarded-For` y la aplicación responde según el estado de la cuenta. Los eventos `LINK_VISIT`, `LOGIN_BLOCKED`, `LOGIN_FAILED`, `LOCKOUT_START` y `LOGIN_SUCCESS` se escriben en `auth.log`; `LOCKOUT_END` lo escribe la aplicación cuando termina el bloqueo.

4. Configuración e implementación

Todo el laboratorio se levanta con Docker Compose en una red aislada (`lab-net`); los puertos publicados al anfitrión están limitados a `127.0.0.1`. El código y las configuraciones están en el repositorio del proyecto.

Componente	Imagen / tecnología	Función	Puerto en el anfitrión
Apache	`httpd:2.4`	Proxy inverso de la aplicación	8081
NGINX	`nginx:1.27-alpine`	Proxy inverso de la aplicación	8082

Componente	Imagen / tecnología	Función	Puerto en el anfitrión
Aplicación (dos copias)	Flask + gunicorn, Python 3.12	Formulario de acceso con la cuenta ficticia	no publicado
ZAP	`zaproxy:stable` en modo daemon	Proxy de captura del usuario 1	8090
Usuario 1	Contenedor Python	Envía las peticiones a través de ZAP	no publicado
Usuario 2	Contenedor Python	Envía las peticiones directo, sin ZAP	no publicado

4.1 Aplicación de prueba

La aplicación ofrece `/login`, `/panel`, `/logout`, `/healthz` y los enlaces cortos `/r/qr1` y `/r/mail1`. Solo existe una cuenta ficticia (`usuario.demo`) con la contraseña almacenada como hash PBKDF2. Funciona en dos modos que se eligen con la variable `CONTROLS_MODE`:

- **`baseline`** (sin controles): sin bloqueo y sin registro de auditoría.
- **`hardened`** (con controles): bloqueo temporal y registro de auditoría.

Los enlaces cortos solo aceptan dos códigos fijos y redirigen únicamente a `/login` de la propia aplicación; no existe redirección abierta hacia otros sitios.

4.2 Bloqueo temporal

- Tras **3 intentos fallidos consecutivos** la cuenta se bloquea **120 segundos**.
- Durante el bloqueo se rechaza también la contraseña correcta (HTTP 429 con `Retry-After`).
- Un acceso correcto reinicia el contador. Al terminar el tiempo se registra `LOCKOUT_END`.
- El tercer fallo responde con un mensaje informativo: "la cuenta quedó bloqueada temporalmente (120 segundos)".
- Los usuarios inexistentes no generan bloqueo, para no revelar qué cuentas existen.

4.3 Registro de autenticación

Cada evento se guarda como una línea JSON con una lista cerrada de campos: fecha y hora, evento (`LINK_VISIT`, `LOGIN_SUCCESS`, `LOGIN_FAILED`, `LOGIN_BLOCKED`, `LOCKOUT_START`, `LOCKOUT_END`), usuario, resultado, IP de origen, contador de fallos, estado de bloqueo y tiempo restante. No existe ningún campo para contraseñas ni tokens.

Limitación observada: el campo usuario se guarda tal como llega. En las pruebas se registró una URL pegada por error en ese campo; si alguien escribiera allí su contraseña, quedaría en el registro. Se recomienda truncar o resumir los nombres de usuario desconocidos.

4.4 Apache y NGINX

Ambos servidores reciben la petición y la reenvían a su copia de la aplicación, con el mismo formato de registro `combined`.

Elemento	Apache (`httpd.conf`)	NGINX (`nginx.conf`)
Proxy	`ProxyPass` y `ProxyPassReverse` hacia `app-apache:8000`	`proxy_pass` hacia `app-nginx:8000` mediante variable y `resolver`
Reenvío de IP	`mod_proxy_http` añade `X-Forwarded-For`	`proxy_set_header X-Forwarded-For $remote_addr` (se sobrescribe, no se concatena)
Versión oculta	`ServerTokens Prod`, `ServerSignature Off`	`server_tokens off`
Encabezado `Server`	`Header always set Server "Apache"`	`proxy_hide_header Server`
Método TRACE	`TraceEnable Off`	no aplica

La aplicación toma la IP del último salto del `X-Forwarded-For` para que un cliente no pueda falsear su origen.

4.5 ZAP

ZAP corre como daemon en el puerto 8090, solo publicado en `127.0.0.1`, con la clave de API desactivada. Esa configuración es solo para este laboratorio aislado y no debe usarse en otro entorno. El usuario 1 envía todo su tráfico a través de ZAP; un script exporta los mensajes capturados a CSV y enmascara los campos del formulario (`username=***&password=***`).

4.6 Capturas de configuración

Las figuras siguen el orden en que se ejecutó y documentó el laboratorio.

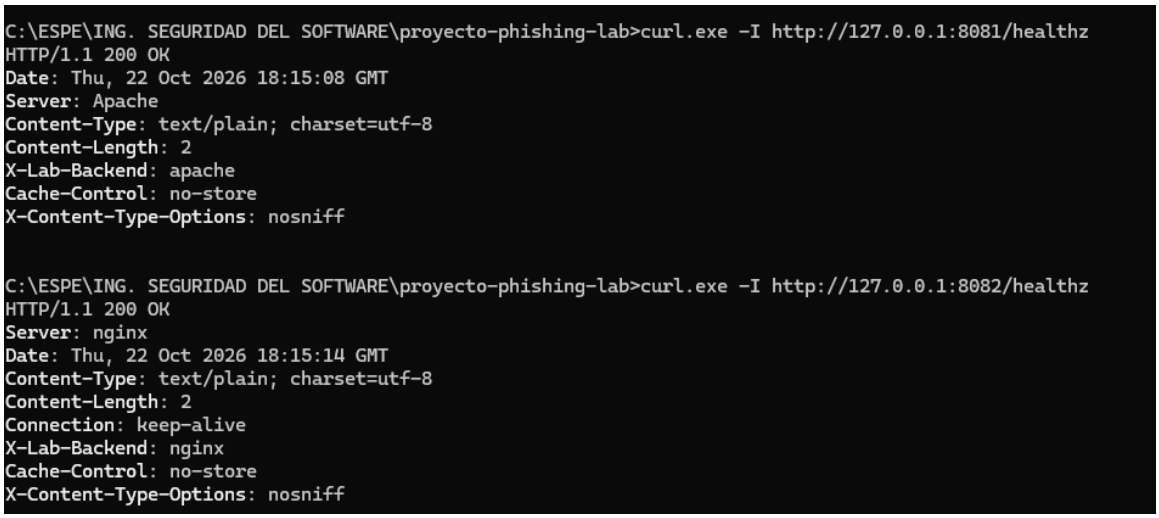


Figura 1. Encabezados de respuesta de Apache y NGINX con `curl -I`: sin `Server: gunicorn` y con los encabezados de seguridad.

```
C:\ESPE\ING. SEGURIDAD DEL SOFTWARE\proyecto-phishing-lab>docker compose ps
NAME                          IMAGE                              COMMAND                  SERVICE      CREATED          STATUS
            PORTS
seg-phishing-lab-apache-1       httpd:2.4                          "httpd-foreground"       apache       11 minutes ago   Up 11 minutes
            127.0.0.1:8081->80/tcp
seg-phishing-lab-app-apache-1   seg-phishing-lab-app-apache        "gunicorn --workers …"   app-apache   11 minutes ago   Up 11 minutes
            8000/tcp
seg-phishing-lab-app-nginx-1    seg-phishing-lab-app-nginx         "gunicorn --workers …"   app-nginx    11 minutes ago   Up 11 minutes
            8000/tcp
seg-phishing-lab-client1-1      seg-phishing-lab-client1           "sleep infinity"         client1      11 minutes ago   Up 11 minutes

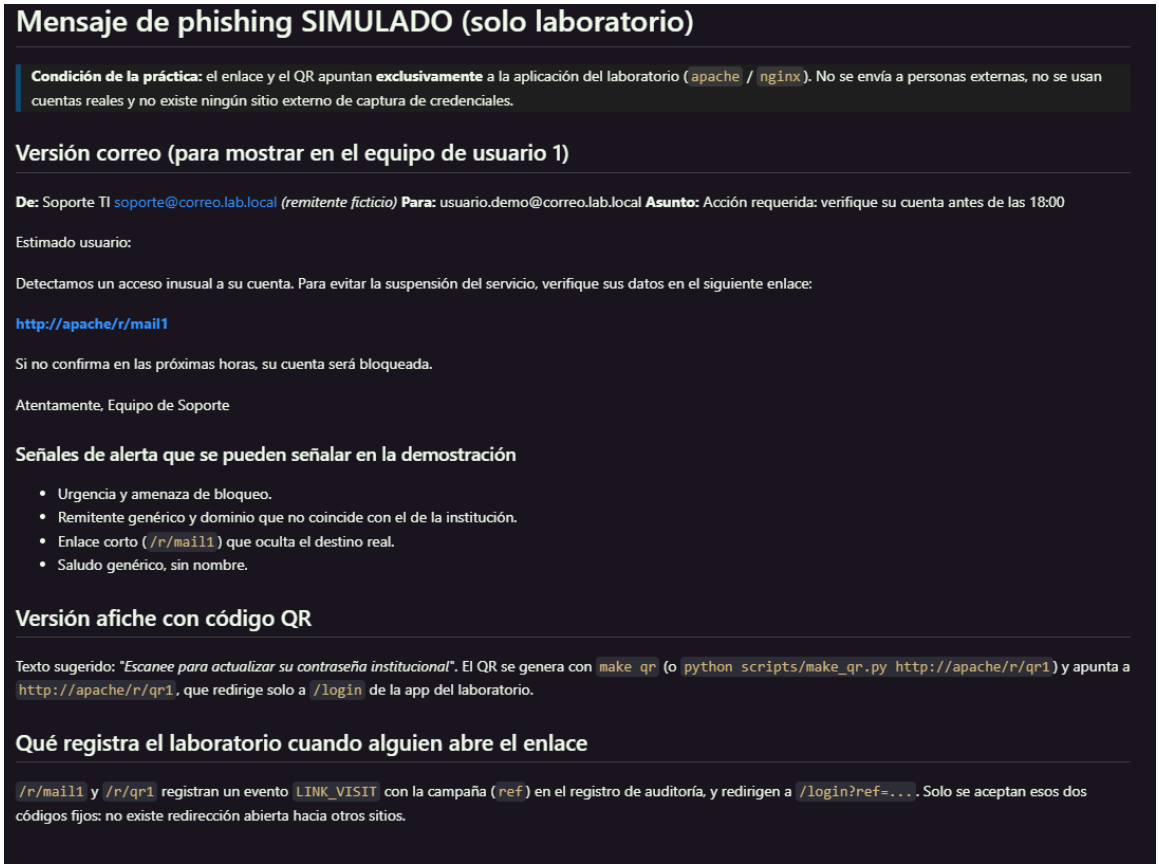
seg-phishing-lab-client2-1      seg-phishing-lab-client2           "sleep infinity"         client2      11 minutes ago   Up 11 minutes

seg-phishing-lab-nginx-1        nginx:1.27-alpine                  "/docker-entrypoint.…"   nginx        11 minutes ago   Up 11 minutes
            127.0.0.1:8082->80/tcp
seg-phishing-lab-zap-1          ghcr.io/zaproxy/zaproxy:stable     "zap.sh -daemon -hos…"   zap          28 seconds ago   Up 26 seconds
 (healthy)  127.0.0.1:8090->8090/tcp
```

Figura 2. Estado de los contenedores con `docker compose ps`, con ZAP en `healthy`.



Figura 3. Página de acceso con el aviso de simulación académica y el mensaje de error de credenciales.



Mensaje de phishing SIMULADO (solo laboratorio)

> **Condición de la práctica:** el enlace y el QR apuntan **exclusivamente** a la aplicación del laboratorio (`apache` / `nginx`). No se envía a personas externas, no se usan cuentas reales y no existe ningún sitio externo de captura de credenciales.

Versión correo (para mostrar en el equipo de usuario 1)

De: Soporte TI soporte@correo.lab.local *(remitente ficticio)* **Para:** usuario.demo@correo.lab.local **Asunto:** Acción requerida: verifique su cuenta antes de las 18:00

Estimado usuario:

Detectamos un acceso inusual a su cuenta. Para evitar la suspensión del servicio, verifique sus datos en el siguiente enlace:

http://apache/r/mail1

Si no confirma en las próximas horas, su cuenta será bloqueada.

Atentamente, Equipo de Soporte

Señales de alerta que se pueden señalar en la demostración

- Urgencia y amenaza de bloqueo.
- Remitente genérico y dominio que no coincide con el de la institución.
- Enlace corto (`/r/mail1`) que oculta el destino real.
- Saludo genérico, sin nombre.

Versión afiche con código QR

Texto sugerido: "*Escanee para actualizar su contraseña institucional*". El QR se genera con `make qr` (o `python scripts/make_qr.py http://apache/r/qr1`) y apunta a `http://apache/r/qr1`, que redirige solo a `/login` de la app del laboratorio.

Qué registra el laboratorio cuando alguien abre el enlace

`/r/mail1` y `/r/qr1` registran un evento `LINK_VISIT` con la campaña (`ref`) en el registro de auditoría, y redirigen a `/login?ref=...`. Solo se aceptan esos dos códigos fijos: no existe redirección abierta hacia otros sitios.

Figura 4. Mensaje de phishing simulado, cuyo enlace apunta solo al laboratorio.



Figura 5. Código QR del afiche simulado (`/r/qr1`).



Figura 6. Página de acceso abierta desde el QR, con `?ref=afiche-qr`.

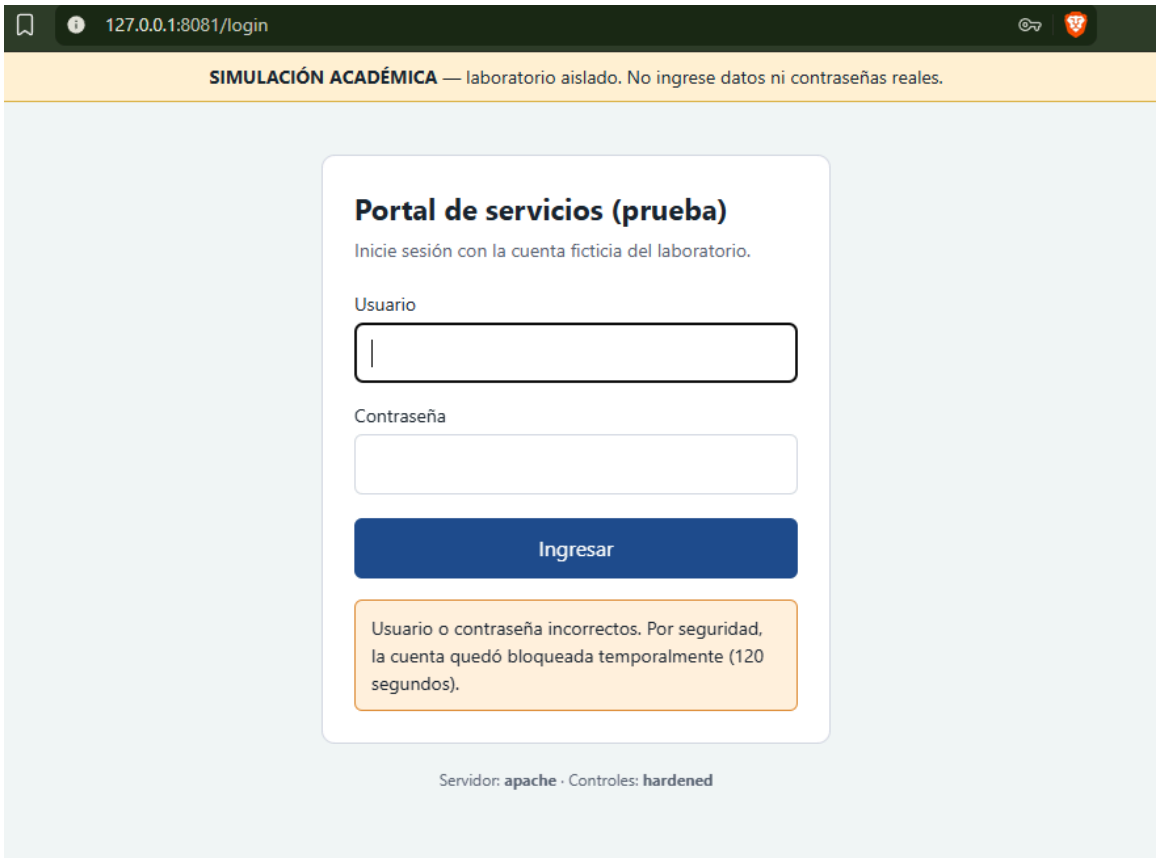
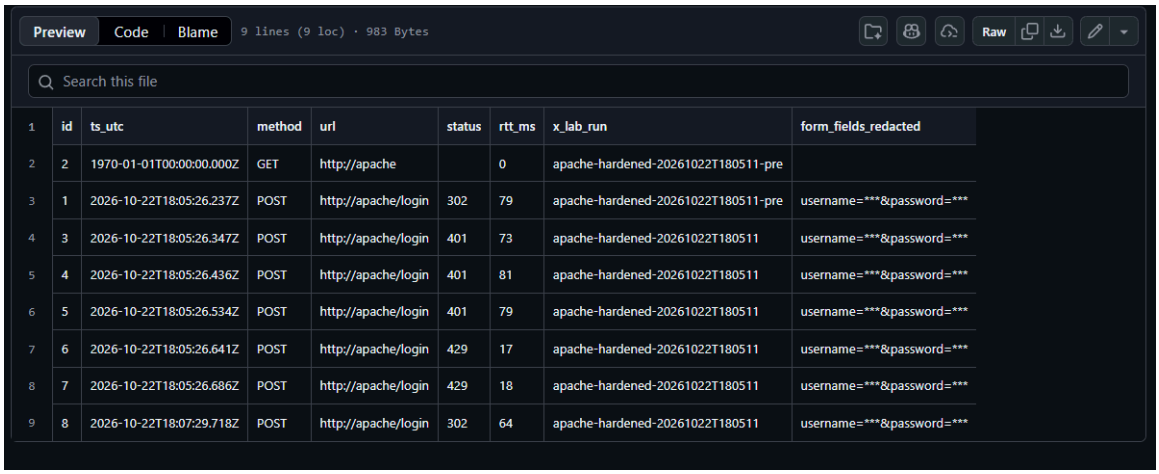


Figura 7. Mensaje de bloqueo tras tres intentos fallidos consecutivos.



Figura 8. Registro de autenticación `auth.Log`, sin contraseñas ni tokens.



	id	ts_utc	method	url	status	rtt_ms	x_lab_run	form_fields_redacted
2	2	1970-01-01T00:00:00.000Z	GET	http://apache		0	apache-hardened-20261022T180511-pre	
3	1	2026-10-22T18:05:26.237Z	POST	http://apache/login	302	79	apache-hardened-20261022T180511-pre	username=***&password=***
4	3	2026-10-22T18:05:26.347Z	POST	http://apache/login	401	73	apache-hardened-20261022T180511	username=***&password=***
5	4	2026-10-22T18:05:26.436Z	POST	http://apache/login	401	81	apache-hardened-20261022T180511	username=***&password=***
6	5	2026-10-22T18:05:26.534Z	POST	http://apache/login	401	79	apache-hardened-20261022T180511	username=***&password=***
7	6	2026-10-22T18:05:26.641Z	POST	http://apache/login	429	17	apache-hardened-20261022T180511	username=***&password=***
8	7	2026-10-22T18:05:26.686Z	POST	http://apache/login	429	18	apache-hardened-20261022T180511	username=***&password=***
9	8	2026-10-22T18:07:29.718Z	POST	http://apache/login	302	64	apache-hardened-20261022T180511	username=***&password=***

Figura 9. Exportación de ZAP (CSV) en el repositorio.



Análisis de registros

1. Registro de auditoría de la aplicación (observado)

Evento	Cantidad
LOCKOUT_END	1
LOCKOUT_START	1
LOGIN_BLOCKED	2
LOGIN_FAILED	3
LOGIN_SUCCESS	2

- Intentos de autenticación registrados: 7 (éxitos 2, fallidos 3, bloqueados 2)
- Usuarios ficticios involucrados: ['usuario.demo']
- IP de origen vistas por la app: ['172.22.0.3']
- Rango de tiempo: 2026-10-22T18:05:26.260Z → 2026-10-22T18:07:29.730Z

Secuencia (línea de tiempo)

Hora (UTC)	Evento	Usuario	Resultado	IP	Fallos	Estado cuenta
2026-10-22T18:05:26.260Z	LOGIN_SUCCESS	usuario.demo	SUCCESS	172.22.0.3	0	unlocked
2026-10-22T18:05:26.349Z	LOGIN_FAILED	usuario.demo	FAILED	172.22.0.3	1	unlocked
2026-10-22T18:05:26.438Z	LOGIN_FAILED	usuario.demo	FAILED	172.22.0.3	2	unlocked
2026-10-22T18:05:26.536Z	LOGIN_FAILED	usuario.demo	FAILED	172.22.0.3	3	locked
2026-10-22T18:05:26.536Z	LOCKOUT_START	usuario.demo	INFO	172.22.0.3	3	locked
2026-10-22T18:05:26.643Z	LOGIN_BLOCKED	usuario.demo	BLOCKED	172.22.0.3	3	locked
2026-10-22T18:05:26.688Z	LOGIN_BLOCKED	usuario.demo	BLOCKED	172.22.0.3	3	locked
2026-10-22T18:07:26.536Z	LOCKOUT_END	usuario.demo	INFO		0	unlocked
2026-10-22T18:07:29.730Z	LOGIN_SUCCESS	usuario.demo	SUCCESS	172.22.0.3	0	unlocked

- Bloqueos activados: 1; finalizados: 1

2. Registros de acceso de los servidores web (observado)

apache

Código HTTP	POST /login
302	2
401	3
429	2

- IP de origen vistas por el servidor: ['172.22.0.3']

3. Solicitudes capturadas por OWASP ZAP (observado)

Código HTTP	POST /login
302	2
401	3
429	2

4. Correlación de conteos

Fuente	Intentos de login contados
Auditoría de la app	7
access.log apache	7
OWASP ZAP	7

Si los números difieren, revise: pruebas previas en el mismo log, la precondición del script (1 login correcto previo), filtros de `--run-id` y que ZAP solo ve el tráfico que pasa por su proxy.

5. Observado vs. interpretado

- **Observado:** conteos, códigos HTTP, horas, IP y estado de bloqueo que aparecen en los archivos.
- **Interpretación (debe justificarse):** una IP por sí sola no demuestra que el intento venga de un atacante, ni si el origen es interno o externo. Cuando el tráfico pasa por ZAP, el servidor ve la IP de ZAP, no la del cliente.
- Las diferencias entre ZAP y los servidores se explican por el punto de captura (proxy vs. servidor vs. aplicación), no necesariamente por errores.

Figura 10. Informe de análisis de registros generado en el repositorio.

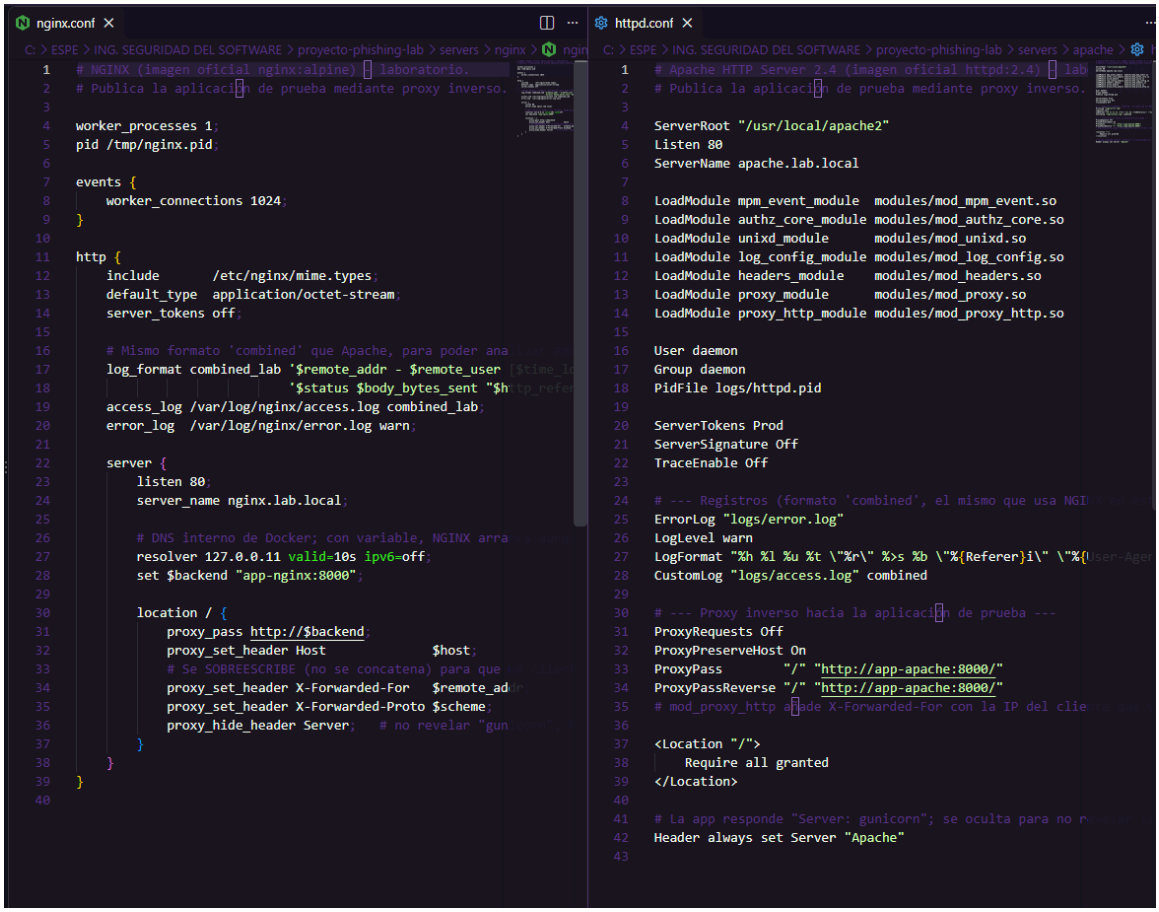


Figura 11. Archivos `httpd.conf` y `nginx.conf` abiertos en el editor.

5. Resultados y análisis de registros

Con controles, el tercer fallo consecutivo bloqueó la cuenta en Apache y en NGINX, y la contraseña correcta fue rechazada hasta que pasaron los 120 segundos. Sin controles, nada de eso ocurrió. Los datos son del 22 de octubre de 2026 y están en `evidence/` del repositorio.

5.1 Escenario ejecutado

El mismo script, desde el usuario 1 (a través de ZAP), ejecuta los mismos pasos en ambos servidores: un acceso correcto previo para dejar la cuenta limpia, tres intentos fallidos consecutivos (S1), un cuarto fallido (S1b), la contraseña correcta durante el bloqueo (S2) y la contraseña correcta después del bloqueo (S3).

Paso	Apache sin controles	NGINX sin controles	Apache con controles	NGINX con controles
S1: 1.º y 2.º fallo	401	401	401	401

Paso	Apache sin controles	NGINX sin controles	Apache con controles	NGINX con controles
S1: 3.º fallo	401	401	401 con mensaje de bloqueo	401 con mensaje de bloqueo
S1b: 4.º fallo	401	401	**429**	**429**
S2: contraseña correcta durante el bloqueo	**302** (entra)	**302** (entra)	**429** (rechazada)	**429** (rechazada)
S3: contraseña correcta tras el bloqueo	302	302	302	302
Intentos registrados por la aplicación	0	0	6	6
Todos los pasos como se esperaba	Sí	Sí	Sí	Sí

El conteo de la aplicación es 6 porque la comparación no cuenta el acceso previo; el análisis de registros sí lo cuenta y da 7.

5.2 Línea de tiempo (Apache con controles)

Hora (UTC, 22/10/2026)	Evento	Fallos	Estado de la cuenta
18:05:26.260	LOGIN_SUCCESS (acceso previo)	0	desbloqueada
18:05:26.349	LOGIN_FAILED	1	desbloqueada
18:05:26.438	LOGIN_FAILED	2	desbloqueada
18:05:26.536	LOGIN_FAILED y LOCKOUT_START	3	bloqueada
18:05:26.643	LOGIN_BLOCKED	3	bloqueada
18:05:26.688	LOGIN_BLOCKED	3	bloqueada
18:07:26.536	LOCKOUT_END	0	desbloqueada
18:07:29.730	LOGIN_SUCCESS	0	desbloqueada

El bloqueo duró exactamente 120 segundos (de 18:05:26.536 a 18:07:26.536). NGINX registró la misma secuencia.

5.3 Correlación entre las tres fuentes

Fuente	Intentos de acceso contados (Apache)	Intentos contados (NGINX)
Registro de auditoría de la aplicación	7	7
`access.log` del servidor	7	7

Fuente	Intentos de acceso contados (Apache)	Intentos contados (NGINX)
ZAP	7	7

En los tres casos los códigos coinciden: dos 302, tres 401 y dos 429. ZAP marca cada petición unas decenas de milisegundos antes que la aplicación (por ejemplo 18:05:26.347 en ZAP y 18:05:26.349 en la aplicación), lo que es coherente con que ZAP está antes en el camino.

El CSV de ZAP tiene 8 filas, no 7: la primera es un `GET http://apache` sin código de respuesta y con fecha `1970-01-01`.

5.4 Pruebas desde el navegador

Después del escenario se probó a mano en Apache con controles:

- `/r/qr1` redirige a `/login?ref=afiche-qr` y la aplicación registra `LINK_VISIT` con la campaña `afiche-qr`.
- Tres contraseñas incorrectas de `usuario.demo` activaron el bloqueo a las 18:19:34 y el fin del bloqueo se registró a las 18:21:34, otra vez 120 segundos después.
- Seis intentos con un usuario inexistente quedaron como `LOGIN_FAILED` con `user_known: false` y nunca se bloquearon.

5.5 Observado frente a interpretado

Observado	Interpretado
Con controles, el 4.º intento y la clave correcta durante el bloqueo dan 429	El bloqueo reduce la probabilidad de adivinar la contraseña, pero no la elimina
Sin controles, la clave correcta entra aun tras 4 fallos	Sin controles no hay límite alguno a la fuerza bruta
Apache y NGINX dieron resultados idénticos	La lógica está en la aplicación, por eso el servidor no cambia el resultado
La IP de origen en los registros del escenario es 172.22.0.3 y la del navegador es 172.22.0.1	172.22.0.3 es ZAP y 172.22.0.1 la puerta de enlace de Docker. Verificado con `docker network inspect`
Los usuarios desconocidos no se bloquean	Es una decisión de diseño para no revelar qué cuentas existen, pero deja sin límite el sondeo de nombres de usuario
El mensaje 8 de ZAP no tiene código ni fecha válida	Parece un nodo del árbol de sitios de ZAP y no tráfico real; no se verificó

Una IP por sí sola no demuestra que el intento venga de un atacante ni si el origen es interno o externo.

6. Matrices de riesgo

Los controles bajaron de Alto a Moderado los riesgos de fuerza bruta (R-01) y de falta de trazabilidad (R-03); los demás no bajaron de nivel. Las dos matrices usan la misma escala, y el archivo completo está en `matrices/matriz_riesgos.xlsx`.

6.1 Escala

Riesgo = Probabilidad × Impacto, con ambos valores de 1 a 5.

Valor	Probabilidad	Impacto
1	Rara	Insignificante
2	Improbable	Menor
3	Posible	Moderado
4	Probable	Mayor
5	Casi segura	Crítico

Nivel	Rango de P × I
Bajo	1 a 4
Moderado	5 a 9
Alto	10 a 16
Crítico	17 a 25

La escala es una convención definida para la práctica. Los valores de probabilidad e impacto son valoraciones del equipo; cada uno está marcado en el archivo como **observado** (respaldado por evidencia del laboratorio) o **juicio** (criterio sin medición).

6.2 Matriz inicial (antes de los controles)

ID	Activo	Amenaza	Impacto	Probabilidad	Nivel
R-01	Cuenta de usuario ficticia en el formulario de acceso	Fuerza bruta o adivinación de contraseñas	3	4	12, Alto
R-02	Credenciales del funcionario expuestas a un mensaje con QR o enlace corto	Phishing	4	4	16, Alto

ID	Activo	Amenaza	Impacto	Probabilidad	Nivel
R-03	Registros de acceso (`auth.log` y `access.log`)	Incidente sin detección ni reconstrucción posible	3	4	12, Alto
R-04	Servidor web Apache	Reconocimiento y explotación de fallas conocidas	3	3	9, Moderado
R-05	Servidor web NGINX	Reconocimiento y explotación de fallas conocidas	3	3	9, Moderado
R-06	Tráfico HTTP de autenticación	Interceptación en la red	4	3	12, Alto

6.3 Matriz residual (después de los controles)

ID	Control implementado	Categoría NIST CSF 2.0	Probabilidad	Impacto	Nivel	Variación
R-01	Bloqueo temporal tras 3 fallos, mensaje informativo y registro de inicio y fin	PR.AA, DE.CM	3	3	9, Moderado	−3
R-02	Registro de la visita al enlace (`LINK_VISIT`) y bloqueo; MFA y capacitación solo recomendados	PR.AT, PR.AA, DE.AE	3	4	12, Alto	−4
R-03	Registro de auditoría sin contraseñas ni tokens	DE.CM, DE.AE	3	3	9, Moderado	−3
R-04	Ocultar la tecnología interna y la versión; `TraceEnable Off`	PR.PS	3	3	9, Moderado	0
R-05	`server_tokens off` y ocultar el encabezado `Server` del backend	PR.PS	3	3	9, Moderado	0
R-06	Ninguno implementado; se recomienda TLS	PR.DS	3	4	12, Alto	0

La justificación de cada valor está en la última columna de la hoja "Residual" del archivo. Tres ejemplos:

- **R-01.** La probabilidad bajó de 4 a 3 porque con controles solo caben 3 intentos por cada 120 segundos (unos 90 por hora por cuenta), frente a intentos ilimitados sin controles. No bajó a 2 porque un ataque lento sigue siendo posible y los usuarios desconocidos nunca se bloquean.
- **R-04 y R-05.** Ocultar la versión reduce la información visible para un atacante, pero no hay evidencia de que el servidor sea menos explotable, por lo que no se bajó el nivel.
- **R-06.** Un control no implementado no reduce el riesgo.

6.4 Riesgos que introduce el propio control

El bloqueo temporal puede usarse para negar el servicio: cualquiera que conozca el nombre de la cuenta puede bloquearla repitiendo tres intentos fallidos cada 120 segundos. Este riesgo no está en la matriz y debe discutirse en las conclusiones.

6.5 Relación con NIST CSF 2.0 e ISO/IEC 27005

Etapa de ISO/IEC 27005	Función NIST CSF 2.0	Evidencia en el proyecto
Identificación y análisis del riesgo	Identificar (ID)	Matriz inicial
Tratamiento del riesgo	Proteger (PR)	Bloqueo, encabezados, cuenta ficticia
Monitoreo y revisión	Detectar (DE)	Registro de auditoría, ZAP, análisis de registros
Riesgo residual	Gobernar (GV)	Matriz residual y su aceptación por el equipo

7. Conclusiones

1. **El bloqueo funciona y se comprobó.** Con controles, el 4.º intento y la contraseña correcta durante el bloqueo dieron 429 en Apache y en NGINX; sin controles, la contraseña correcta entró aun después de 4 fallos.
2. **El riesgo bajó, pero no desapareció.** La fuerza bruta (R-01) y la falta de trazabilidad (R-03) pasaron de Alto (12) a Moderado (9). El phishing (R-02) y el tráfico sin cifrar (R-06) siguen en Alto (12), porque el bloqueo no impide usar credenciales ya entregadas ni cifra el tráfico.
3. **La trazabilidad quedó verificada.** La auditoría de la aplicación, el `access.log` y ZAP contaron 7 intentos cada uno en ambos servidores, y el bloqueo duró exactamente 120 segundos.
4. **El servidor web no cambió el resultado.** Apache y NGINX dieron lo mismo porque la lógica de seguridad está en la aplicación. Sus diferencias de rendimiento no se midieron.
5. **El control introduce un riesgo propio.** Cualquiera que conozca un nombre de cuenta puede bloquearla repitiendo tres intentos fallidos cada 120 segundos.

8. Recomendaciones

Recomendación	Riesgo que atiende	Categoría NIST CSF 2.0
Habilitar HTTPS con TLS en Apache y NGINX	R-06	PR.DS
Agregar autenticación multifactor	R-01, R-02	PR.AA
Limitar intentos también por dirección IP y no solo por cuenta, y aplicar límites a los usuarios desconocidos	R-01 y el riesgo de bloqueo malicioso	PR.AA
Enviar los registros a un servidor central con alertas y revisión	R-03	DE.CM, DE.AE
Truncar o resumir en el registro los nombres de usuario desconocidos	R-03	PR.DS
Capacitación y simulacros periódicos de phishing con QR y enlaces	R-02	PR.AT
Parches periódicos y escaneo de vulnerabilidades de los servidores	R-04, R-05	PR.PS

9. Limitaciones

- El laboratorio usa **HTTP sin TLS**; las credenciales viajan sin cifrar dentro de la red aislada.
- Hay una **sola cuenta ficticia** y un solo atacante simulado. No se probó un ataque distribuido desde varias IP.
- El código QR apunta al nombre interno `apache` y solo se abre dentro del laboratorio; desde el anfitrión se probó con `http://127.0.0.1:8081/r/qr1`.
- El rendimiento de Apache y NGINX **no se midió**.
- Los valores de probabilidad e impacto son valoraciones del equipo; cada uno está marcado como observado o juicio en la matriz.
- La IP de origen mostrada en los registros (172.22.0.3 y 172.22.0.1) se verificó con `docker network inspect`.
- Las etapas de ISO/IEC 27005 se describieron desde el esquema general de la norma, que es de pago y no se pudo consultar completa.

10. Bibliografía

Apache Software Foundation. (s. f.). *Apache MPM event*. Apache HTTP Server Version 2.4 Documentation. https://httpd.apache.org/docs/mod/event.html

EcuCERT. (2022, 25 de febrero). *Aviso de seguridad EC-2022-41: Campaña de phishing Banco Pichincha*. Centro de Respuesta a Incidentes Informáticos del Ecuador.

https://www.ecucert.gob.ec/wp-content/uploads/2022/04/EC-2022-41-Aviso-de-seguridad-Campana-de-phishing-Banco-Pichincha-1.pdf

Garrett, O. (2015, 10 de junio). *Inside NGINX: How we designed for performance & scale*. NGINX Community Blog. https://blog.nginx.org/?p=5201

IEC Webstore. (2022a). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (3.ª ed.). https://webstore.iec.ch/publication/79694

IEC Webstore. (2022b). *ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks* (4.ª ed.). https://webstore.iec.ch/publication/79713

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

Peñafiel Robalino, M. T. (2024, 22 de noviembre). Alerta por estafa a través de WhatsApp y códigos QR en Ecuador. *La Prensa*. https://laprensa.com.ec/alerta-por-estafa-a-traves-de-whatsapp-y-codigos-qr-en-ecuador/

Segu-Info. (2011). *Phishing to Banco Bradesco abuses short URLs of bit.ly: More than 5% fall deceived*. Ventas de Seguridad. https://www.ventasdeseguridad.com/en/news/latest-news/434-computer-security/14634-phishing-to-banco-bradesco-abuses-short-urls-of-bit-ly-more-than-5-fall-deceived.html

ZAP. (s. f.). *Manipulator-in-the-middle proxy*. ZAP Documentation. https://www.zaproxy.org/docs/desktop/start/features/intercept